

Catatan audit SALE — 20 September 2026

Project belum siap untuk data akademik nyata. Penyebab utama adalah pencampuran data pratinjau per sesi dengan data institusi di database, autentikasi persona yang menjadi autentikasi database, serta aturan nilai/kuis yang berbeda antarjalur.

Baseline: commit 0ff437d beserta perubahan lokal pada LearningController, route, view course/discussions/item, dan LearningWorkflowTest yang sudah ada sebelum audit. Audit tidak memperbaiki kode aplikasi. Lokasi baris mengacu pada baseline tersebut.

Cakupan dan batas pemeriksaan

Pemetaan route seluruh peran; penelusuran alur course, enrollment, konten, submission, kuis, nilai, OBE, rubrik, admin/prodi, AI dan runner; struktur repository dan panduan setup; pengujian fitur yang ada, proof-of-concept terisolasi, build, format dan dependency advisory. Inventaris awal: 289 tracked files, 28 controller, 79 Blade views. Ini audit source dan pengujian aplikasi terpilih, bukan verifikasi setiap kombinasi input atau audit deployment production. Browser E2E, beban, race condition nyata, konfigurasi server/TLS/backup, scan seluruh riwayat Git untuk secret, dan evaluasi Gemini langsung belum dilakukan. Tidak ada klaim bebas kerentanan.

P0 = blocker penggunaan data nyata; P1 = integritas/akses penting; P2 = konsistensi dan pemeliharaan. **Teruji** berarti direproduksi di SQLite memory menggunakan [AuditReproductionTest.php](#); test yang lulus justru membuktikan perilaku bermasalah masih ada. **Statis** berarti bukti source, belum reproduksi browser atau eksploitasi eksternal.

Konsistensi fitur

ID / prioritas	Temuan, bukti, dan dampak	Perbaikan / kriteria penerimaan
F01 P1 — statis	<code>LearningPreview::courses/items</code> , <code>AdminPreview::users/academic</code> , <code>AcademicPreview</code> menyimpan domain terkait di sesi, sementara model <code>ClassSection</code> / <code>Assessment</code> / <code>User</code> memakai DB. <code>Course</code> / <code>tugas</code> / <code>diskusi</code> yang dibuat dosen tidak dibagikan ke browser mahasiswa; admin institusi dan admin-prodi memakai sumber berbeda.	Pilih DB sebagai sumber utama, relasikan <code>course-kelas-konten-submission-nilai</code> . Test dua sesi independen: dosen membuat tugas, mahasiswa menerima, dosen melihat jawaban.

ID / prioritas	Temuan, bukti, dan dampak	Perbaikan / kriteria penerimaan
F02 P1 — teruji	<code>LearningController.php:13,67</code> memasukkan ID <code>ClassSection</code> ke kartu <code>course</code>, tetapi detail mengambil <code>LearningPreview::course</code>. ID 1 database membuka Struktur Data pratinjau, walaupun nama kelas DB berbeda; ID di luar array menjadi 404. <code>DashboardController</code> mengulang pola ini.	Route/resource eksplisit untuk kelas DB; jangan menyamakan ID dua sumber. Klik setiap kartu harus membuka kelas yang sama, termasuk ID >4.
F03 P1 — teruji	<code>ClassSectionController.php:52</code> menyertakan dosen pendamping; <code>PenilaianController.php:330</code>, <code>Assessment/Export/InputNilai/Rubric</code> ownership hanya dosen utama. Pendamping melihat kelas lalu mendapat 403.	Satu policy dengan hak pendamping yang disepakati, diterapkan pada daftar dan aksi.
F04 P1 — teruji	<code>AcademicController.php:119</code> selalu menulis <code>academic.item_grades.{item}.1</code>; <code>LearningController.php:288</code> submission hanya keyed per item. Nilai mahasiswa lain masuk ke mahasiswa 1 dan akun berbagi browser saling menimpa submission. <code>learning/grades.blade.php:173</code> breakdown CPMK juga tidak meneruskan <code>studentId</code>.	Key submission dan grade berdasarkan user terautentikasi + assessment + attempt. Test minimal dua mahasiswa.
F05 P1 — teruji	<code>LearningController.php:77</code> mengacak pertanyaan, view mengirim jawaban berdasarkan indeks tampilan; <code>submit:288</code> memvalidasi indeks urutan asli. Jawaban pilihan yang benar secara format bisa ditolak sebagai pilihan soal lain; jawaban uraian berisiko salah atribusi.	Gunakan question ID stabil, validasi terhadap attempt order server, dan uji shuffle campuran tipe.
F06 P1 — teruji/status	<code>UI quiz-room.blade.php:95</code> menjanjikan terkunci, tetapi POST submission menerima overwrite setelah selesai (teruji). Timer di <code>localStorage</code> sekitar baris 833 tidak memiliki <code>started_at/expires_at</code> server (statis). Flag <code>from_quiz_room</code> juga mengizinkan jawaban kosong.	State attempt server, waktu server, finalisasi atomik dan idempotent; resubmission setelah final ditolak. Jawaban kosong boleh hanya sesuai kebijakan ujian, bukan karena flag client dipercaya.
F07 P1 — statis	<code>quiz-room.blade.php:1151</code> tombol Run hanya menunggu 400 ms lalu menampilkan BST sukses tanpa menjalankan input. Room coding terpisah memakai runner nyata.	Pakai runner yang sama atau tandai tombol sebagai simulasi; kode invalid tidak boleh menampilkan hasil lulus.
F08 P1 — teruji	<code>ObeProgressController.php:34,46</code> dan monitoring CPMK tidak mengirim <code>classSectionId</code>; <code>ObeCalculationService.php:137</code> memilih enrollment pertama. Dua kelas MK sama dengan nilai 20 dan 90	Teruskan section/semester eksplisit; uji pengambilan ulang

ID / prioritas	Temuan, bukti, dan dampak	Perbaikan / kriteria penerimaan
	menghasilkan 20 ketika scope dihilangkan.	MK lintas semester.
F09 P1 — teruji	InputNilai menyimpan total parsial, lalu <code>ObeCalculationService.php:305</code> memakai total itu sebagai fallback untuk sel CPMK NULL. Contoh bobot 50/50, nilai 40/50 dan kosong: hasil akhir 60, coverage 100%, CPMK belum dinilai diberi 40.	Bedakan tidak ada nilai rinci dengan nilai rinci yang masih NULL. Pada contoh ini coverage harus 50%, nilai provisional 80, CPMK kedua NULL.
F10 P1 — teruji	<code>RubricController.php:49</code> melewati penghapusan kriteria yang punya nilai, tanpa menolak request atau menghitung ulang bobot akhir. Mengganti kriteria lama berbobot 100 dengan baru 100 menyisakan total 200.	Tolak perubahan yang tidak valid atau versioning rubrik; validasi bobot pada kondisi DB akhir, bukan hanya payload.
F11 P1 — statis	<code>KaprodiMonitoringController.php:69</code> mengumpulkan nilai setiap mahasiswa di setiap kelas tanpa deduplikasi; mahasiswa yang ikut banyak kelas dihitung berulang. CPL memakai semua semester, CPMK hanya semester aktif.	Definisikan populasi unik mahasiswa/prodi/semester dan kebijakan retake, samakan filter laporan.
F12 P1 — teruji	<code>AkademikProdiController.php:146,178</code> dosen_id hanya <code>exists:users,id</code> . Akun mahasiswa diterima sebagai pengampu kelas.	Validasi role dan scope prodi di server untuk dosen utama/pendamping; request manipulasi ID harus 422/403.
F13 P2 — statis	Kartu preview <code>learning/partials/course-card.blade.php:14</code> membuat kode enrollment dari kode course + tahun, sementara join mencari kode acak DB. QR preview mengarah ke kelas tidak terdaftar. Juga ada fallback layanan QR eksternal meski README menyebut frontend tanpa CDN.	Tampilkan QR hanya untuk ClassSection nyata; gunakan generator lokal yang sama.
F14 P2 — statis	Notifikasi selalu mengatakan Menunggu penilaian meski nilai telah diisi; grafik IP/IPK dan profil tetap contoh. Assignment coding dapat mengambil judul dari <code>ai_tasks</code> sementara daftar tetap LearningPreview.	Status dan identitas diambil dari domain yang sama; beri label demo yang konsisten sampai integrasi selesai.
F15 P1 — teruji	Dosen dapat masuk ke ruang ujian CBT mahasiswa (<code>/mahasiswa/course/{course}/item/{item}/quiz</code>) dan mengerjakan kuis dengan UI ujian lengkap (timer, navigasi soal, tombol kumpulan kuis). Pada <code>course.blade.php</code> , tombol untuk akun dosen tetap berlabel "Kerjakan →", dan pada <code>item.blade.php:121</code> tombol "Mulai Kerjakan Kuis" tidak dibungkus <code>@if(!\$isLecturer)</code> .	Tambahkan guard peran di <code>quizRoom()</code> (<code>abort_if(dosen, 403)</code>) dan sembunyikan tombol pengerjaan kuis bagi dosen. Sediakan antarmuka manajemen/editor butir soal

ID / prioritas	Temuan, bukti, dan dampak	Perbaikan / kriteria penerimaan
F16 P1 — teruji	Sebaliknya, dosen sama sekali tidak memiliki fitur edit butir soal atau edit kuis setelah konten dibuat (<code>item.store</code> ada, tetapi <code>item.edit/item.update</code> tidak tersedia). Teruji di PoC <code>AuditReproductionTest</code> .	(<code>dosen.item.edit/update</code>) dan pratinjau soal (read-only) khusus dosen.
	Berkas lampiran submission tersimpan terisolasi pada sesi browser pengunggah: <code>LearningController::upload()</code> menyimpan metadata file di <code>session("learning.files.\$uuid")</code> . Ketika dosen memeriksa tugas mahasiswa di browser lain, sesi dosen tidak memiliki metadata UUID tersebut, sehingga <code>LearningController::file()</code> mengembalikan 404 Not Found dan <code>SubmissionPreview::files()</code> mengembalikan daftar kosong. Dosen secara sistemik tidak dapat melihat ataupun mengunduh berkas jawaban mahasiswa. Teruji di PoC <code>AuditReproductionTest</code> .	Simpan metadata lampiran dan relasi submission di database; izinkan dosen pengampu dan mahasiswa bersangkutan mengunduh berkas; hilangkan ketergantungan metadata berkas pada sesi browser.
	Terdapat tiga rute capaian/nilai mahasiswa yang terpisah dan saling bertentangan di portal mahasiswa: <code>/mahasiswa/grade</code> (redirect ke tab nilai assignment dengan data <code>LearningPreview</code>), <code>/mahasiswa/nilai</code> (menampilkan <code>AcademicPreview</code> dengan CPL/CPMK sesi), dan <code>/mahasiswa/capaian-obe</code> (menghitung pencapaian OBE dari DB lewat <code>ObeCalculationService</code>). Ketiganya menampilkan angka, status, dan riwayat yang berbeda pada akun yang sama.	Satukan navigasi transkrip/nilai mahasiswa ke satu rute kanonikal berbasis database yang selaras dengan nilai riil dari dosen dan kalkulasi OBE.
F18 P2 — statis	Tiga controller mahasiswa di <code>app/Http/Controllers/Mahasiswa/</code> (<code>CourseController.php</code> , <code>DiscussionController.php</code> , dan <code>GradeController.php</code>) merupakan dead code / skeleton yang tidak pernah dipanggil oleh route manapun di <code>routes/web.php</code> . Logika pembelajaran justru ditangani secara tumpang tindih di <code>LearningController.php</code> dan <code>AcademicController.php</code> . <code>CourseController::show</code> bahkan memuat batas kaku <code>abort_unless(in_array(\$course, [1, 2, 3, 4], true), 404)</code> .	Bersihkan atau hubungkan controller mahasiswa tersebut ke resource database yang nyata; hapus duplikasi tanggung jawab antara <code>LearningController</code> dan controller spesifik peran.

Keamanan

ID / prioritas	Bukti dan risiko	Perbaikan / kriteria penerimaan
S01 P0 — teruji	<code>EnsureAdminProdiAuth.php</code> otomatis <code>Auth::login</code> akun admin pertama untuk guest. <code>KaprodiMonitoringController.php:108</code> punya fallback	Hapus autologin; guest ditolak/redirect. Pratinjau

ID / prioritas	Bukti dan risiko	Perbaikan / kriteria penerimaan
	serupa (statis).	harus terpisah dan tidak menyentuh akun DB.
S02 P0 — teruji	AuthController.php:45,116,222 menerima password kosong, password literal demo, serta public switch-role ke akun DB. PoC switch dosen membuka riwayat /ai/tasks/1 bila akun tersebut punya ai_access. Login AI yang benar tidak menutup pintu masuk lain pada guard yang sama.	Auth::attempt dengan hash password, disable persona di lingkungan data nyata, satukan identitas server. Uji semua jalur login dan akses AI tanpa password.
S03 P0 — teruji	AdminProdi/UserProdiController.php:92 menerima User arbitrer tanpa batas role/prodi. Admin prodi berhasil mengganti password admin sistem dari prodi lain. Scope prodi juga tidak ditegakkan hanya dengan dropdown filter.	Policy role+tenant pada query dan mutation, larang perubahan privileged user melalui endpoint dosen/mahasiswa.
S04 P1 — teruji	Route /kelas/{id}/barcode dan /qr publik; controller sekitar baris 233 tidak memeriksa akses. Kode enrollment bisa dibaca dari ID berurutan.	Lindungi generator QR/kode dengan policy; jangan perlakukan kode sebagai rahasia selama bisa diekstrak publik.
S05 P1 — teruji/statis	/logout hanya menghapus auth_user; jawaban sesi lama tetap ada (teruji). Draf kode app.js:159 hanya keyed assignment, tidak user; berpindah akun di browser lab dapat melihat draf lama (statis).	Invalidasi sesi dan regenerasi CSRF; namespace/pembersihan draft per akun dengan kebijakan pemulihan jelas.
S06 P1 — statis	/join-kelas/{code} melakukan attach lewat GET. Pemeriksaan kapasitas dan attach tidak atomik. /switch-role dan logout juga menerima GET mutatif.	Enrollment POST dengan CSRF, konfirmasi user, transaksi/locking kapasitas dan uniqueness; GET hanya halaman baca. Race condition belum diuji konkuren.
S07 P2 — teruji	ExportController CSV dan template InputNilai menulis nama tanpa netralisasi formula. PoC nama =1+1 keluar sebagai formula cell. AdminPreview export justru sudah menetralkannya.	Terapkan encoder CSV konsisten pada field teks; uji pembukaan spreadsheet terpisah. Audit hanya membuktikan payload

ID / prioritas	Bukti dan risiko	Perbaikan / kriteria penerimaan
		diekspor, bukan eksekusi pada Excel.
S08 P1 — statis	<code>DosenAccountSeeder.php:20</code> menggunakan <code>updateOrCreate</code> dan <code>password</code> literal demo; <code>DatabaseSeeder</code> selalu memanggilnya. Seed ulang bisa mereset password akun demo yang sudah diubah.	Pisahkan seeder demo dari <code>deploy production</code> , jangan <code>overwrite</code> kredensial existing; bootstrap admin melalui proses khusus.
S09 P1 — statis	Route grup <code>mahasiswa.*</code> , <code>dosen.*</code> , dan <code>kaprodi.*</code> tidak menggunakan middleware autentikasi apapun (komentar "Public only while SALE remains a frontend prototype"). Hanya <code>admin-prodi.*</code> yang punya <code>middleware('admin_prodi.auth')</code> . Ketika data institusi nyata dimasukkan, semua endpoint mahasiswa/dosen/kaprodi dapat diakses tanpa sesi.	Buat <code>EnsureMahasiswaAuth</code> dan terapkan ke grup <code>mahasiswa.*</code> ; terapkan <code>dosen.auth</code> ke <code>dosen.*</code> ; buat <code>EnsureKaprodiAuth</code> untuk <code>kaprodi.*</code> .
S10 P0 — teruji	Route grup <code>admin.*</code> (<code>routes/web.php:100</code>) dan rute aksi penilaian dosen (<code>/dosen/gradebook</code> , <code>/dosen/penilaian/{item}</code> , <code>/dosen/course/{course}/akademik</code>) tidak memiliki middleware autentikasi . <code>AdminPreviewController</code> tidak memeriksa auth sama sekali. Siapa pun dapat membuka <code>/admin/pengguna</code> , <code>/admin/akademik</code> , serta memicu POST mutatif seperti reset data akademik tanpa login. Teruji di PoC <code>AuditReproductionTest</code> .	Terapkan middleware auth dan role guard (<code>EnsureAdminAuth</code> / <code>EnsureDosenAuth</code>) pada seluruh rute admin dan aksi penilaian dosen.
S11 P0 — teruji	<code>KaprodiMonitoringController::authorizeKaprodi()</code> mengandung autologin fallback: jika pengguna adalah guest yang tidak memiliki sesi <code>auth_user</code> , controller secara otomatis mencari kaprodi pertama di database dan memanggil <code>Auth::login()</code> . Cukup dengan mengunjungi <code>/kaprodi/monitoring/cpl</code> , siapa pun di internet otomatis di-login-kan sebagai Kaprodi institusi. Teruji di PoC <code>AuditReproductionTest</code> .	Hapus autologin fallback; kembalikan redirect login atau 403 untuk guest unauthenticated.
S12 P1 — statis	Route GET <code>/preview/files/{uuid}</code> tidak memiliki middleware auth. File dapat diakses siapa pun yang mengetahui UUID-nya, tanpa verifikasi hak kepemilikan submission dan tanpa masa kedaluwarsa (TTL).	Pasang middleware auth dan periksa otorisasi apakah user yang me-request adalah pengunggah atau dosen kelas terkait.
S13 P2 — statis	<code>UserProdiController::import()</code> hanya memvalidasi <code>'file' => ['required', 'file', 'max:4096']</code> tanpa batasan ekstensi atau validasi MIME (<code>mimes:csv,txt</code>). File binary atau script arbitrer dapat diunggah	Tambahkan aturan validasi <code>mimes:csv,txt,xlsx</code> pada

ID / prioritas	Bukti dan risiko	Perbaikan / kriteria penerimaan
	ke server.	import akun.
S14 P1 — statis	<code>destroyCpl</code> pada <code>KurikulumController.php:94</code> menjalankan <code>\$cpl->cpmks()->detach()</code> lalu <code>\$cpl->delete()</code> tanpa validasi keterkaitan dengan asesmen aktif. Sesuai skema migrasi <code>create_student_assessment_cpmk_scores_table</code>, cascade delete pada foreign key CPMK akan secara instan menghapus seluruh rekam nilai CPMK mahasiswa tanpa konfirmasi atau peringatan dampak.	Tambahkan proteksi sebelum penghapusan CPL/CPMK; tolak penghapusan bila sudah memiliki data penilaian mahasiswa.

Kontrol yang sudah berguna: upload tervalidasi dan file privat per sesi; nosniff dan anti-framing; ownership assessment-section di jalur penilaian DB; AI access per task, rate limit dan quota; eksekusi Python browser di worker serta runner server opsional tidak menjalankan kode langsung di host Laravel. Kontrol tersebut perlu dipertahankan, tetapi tidak menutup bypass autentikasi global. Tidak ada klaim SQLi/RCE/XSS terkonfirmasi dari pemeriksaan ini.

Struktur repository dan serah terima

ID / prioritas	Temuan	Tindakan yang disarankan
M01 P1	README mengatakan autentikasi/enrollment belum terhubung, tetapi sekarang ada mutation DB; docs AI menyebut persona tidak bisa mengakses AI, bertentangan dengan S02.	Buat matriks fitur demo/persisten/operasional, diagram domain dan alur auth, serta daftar keterbatasan yang sesuai source.
M02 P1	<code>phpunit.xml</code> menunjuk tests/Unit yang tidak ada; perintah test README gagal sebelum menjalankan suite. Feature suite terpisah juga punya satu kegagalan GradebookAttainmentTest (teks "Ketercapaian CPMK" case-sensitive mismatch).	Perbaiki konfigurasi suite; ubah teks di <code>gradebook.blade.php:12</code> dari huruf kecil menjadi kapital, atau sesuaikan ekspektasi test.
M03 P2	app.js 1.650 baris, quiz-room 1.203, item 732, AdminLaporanService 820. Blade memuat logika domain; ownership berulang di beberapa controller.	Pisahkan modul frontend quiz/editor/tutor dan domain service + policy + FormRequest. Pecah berdasarkan tanggung jawab, bukan sekadar jumlah baris.
M04 P2	Dua sistem penilaian AcademicPreview dan ObeCalculationService; view/controller lama tetap ada di samping	Inventaris route→controller→view→storage;

ID / prioritas	Temuan	Tindakan yang disarankan
	jalur baru. Contoh dashboard lama sengaja disimpan.	tandai legacy/demo, tentukan migrasi sebelum menghapus. Jangan menganggap semua file lama aman dihapus.
M05 P2	Tidak ada tracked CI workflow, CONTRIBUTING, SECURITY, ADR atau runbook deploy/restore. composer.json menyebut MIT tetapi LICENSE tidak ditemukan.	Tambahkan onboarding, aturan PR, checks CI, matriks peran, ERD, keputusan formula OBE, backup/restore dan ownership modul; pastikan lisensi dengan pemilik project.
M06 P2	Pint gagal; browser test membutuhkan Playwright yang tidak ada pada manifest. Mesin audit Node 26 sedangkan engines Node 22; build sukses tidak membuktikan clean install Node 22.	Pin runtime CI sesuai .nvmrc, dokumentasikan dependency browser dan command test JS, rapikan formatting terpisah.
M07 P2	File upload sesi tidak punya lifecycle cleanup otomatis; log AdminPreview hanya sesi dengan actor tetap, mutation DB tidak tercakup log itu.	Retensi/cleanup lampiran dan audit log persisten untuk perubahan pengguna, enrollment dan nilai.
M08 P1	Halaman item dosen (<code>item.blade.php</code>) memperlakukan dosen secara tidak konsisten: untuk item <code>tugas</code> dosen melihat panel kelola, tetapi untuk <code>kuis</code> tombol "Mulai Kerjakan Kuis" tetap muncul (F15). Tombol pada course overview juga bertuliskan "Kerjakan →" bagi dosen. Lebih parah, dosen tidak memiliki fitur edit butir soal atau edit kuis sama sekali setelah pembuatan (<code>item.store</code> ada tanpa <code>item.edit/update</code>). Panel dosen di item mengarah ke <code>dosen.gradebook</code> yang berbasis sesi <code>AcademicPreview</code> , terputus dari penilaian OBE database.	Pisahkan route dan antarmuka pratinjau soal khusus dosen dari form ujian CBT mahasiswa. Buat antarmuka editor butir soal (<code>dosen.item.edit/update</code>) dan pratinjau read-only untuk pengampu.
M09 P2	Controller mahasiswa di <code>app/Http/Controllers/Mahasiswa/</code> (<code>CourseController.php</code> , <code>DiscussionController.php</code> , dan <code>GradeController.php</code>) dibiarkan mengendap sebagai dead code / stub tanpa didaftarkan pada routing <code>routes/web.php</code> . Semua alur tersebut ditangani tumpang tindih oleh <code>LearningController.php</code> . <code>CourseController::show</code> bahkan memuat pembatasan ID kaku [1, 2, 3, 4].	Bersihkan atau aktifkan controller modular per peran yang terhubung ke model database nyata, dan hapus Controller stub yang mengaburkan arsitektur.

Struktur Laravel dasarnya sudah sesuai konvensi. Tidak perlu rewrite framework. Prioritaskan sumber data dan policy tunggal; reorganisasi folder mengikuti keputusan itu.

Hasil verifikasi

Pemeriksaan	Hasil
<code>php artisan test --compact</code>	Terhenti: tests/Unit tidak ditemukan
<code>php artisan test -- testsuite=Feature --compact</code>	120 lulus, 1 gagal, 1.223 assertions; GradebookAttainmentTest mengharapakan teks Ketercapaian CPMK
PoC audit eksplisit	21 lulus, 70 assertions; membuktikan defect teruji
<code>node --test tests/js/*.test.mjs tests/grade-import.test.js</code>	4 file test lulus
<code>npm run build</code>	Berhasil
<code>composer validate --no-check- publish</code>	Valid
<code>vendor/bin/pint --test</code>	Gagal: formatting source existing dan file PoC; tidak dijalankan mode fix
<code>composer audit --locked -- format=json</code>	Advisory dan abandoned kosong pada waktu audit
<code>npm audit --json</code>	0 vulnerability yang dikenal pada waktu audit
Strix	Setup terpisah; scan dimulai di session sebelumnya tetapi terhenti; belum ada hasil
Temuan tambahan (audit komprehensif)	F15-F18, S10-S14, M08-M09 ditambahkan: dosen ujian CBT tanpa fitur edit soal, isolasi file lintas sesi (404), route admin/penilaian tanpa auth, kaprodi autologin, cascade delete CPL.

Untuk mengulangi PoC: `vendor/bin/phpunit -c phpunit.xml`
`docs/audits/2026-09-20/evidence/AuditReproductionTest.php --testdox`. Gunakan environment testing SQLite memory, bukan database institusi. Setelah perbaikan, ubah ekspektasi PoC menjadi perilaku aman dan pindahkan ke suite regresi normal.

Urutan pekerjaan

1. **Tutup S01, S02, S03, S10, S11 sebelum data nyata** — hapus semua autologin (admin prodi & kaprodi), terapkan middleware auth di semua route grup (admin, mahasiswa, dosen, kaprodi), batasi mutasi ke peran yang berwenang.

2. Tambah guard role pada S09, amankan S12 (file download authorization), S13 (import MIME validation), dan S14 (proteksi cascade delete CPL/CPMK).
3. Tetapkan model domain DB dan policy tunggal, lalu perbaiki F01–F04 serta alur enrollment.
4. Perbaiki integritas attempt, penilaian, dan file submission F05–F18 dengan regresi multi-user/multi-semester.
 - Termasuk F15 & M08: cegah dosen masuk CBT ujian, sediakan antarmuka edit butir soal kuis (`item.edit/update`), dan pratinjau soal read-only.
 - Termasuk F16: migrasikan metadata berkas dan submission ke DB agar dapat diakses dosen pengampu.
 - Termasuk F17 & M09: satukan halaman capaian nilai mahasiswa dan bersihkan controller skeleton yang tidak terpakai.
5. Sinkronkan dashboard/notifikasi/AI dan ekspor dengan sumber data yang sama.
6. Fix GradebookAttainmentTest (M02): ubah teks view atau sesuaikan test — 1 baris.
7. Jadikan test/build/format/static analysis sebagai gate CI dan lengkapi runbook handover.
8. Jalankan Strix pada snapshot/staging sintetis; triage hasil terhadap temuan di atas.

Repository pelengkap yang diperiksa: [OWASP ASVS](#) untuk kerangka persyaratan keamanan, [Larastan](#) untuk analisis statis Laravel, dan [Strix](#). ASVS/Larastan belum dijalankan sebagai checklist formal/tool; jumlah star tidak dijadikan bukti kualitas atau pengganti pengujian alur bisnis. Setup Strix ada di [panduan keamanan](#).